

Section 04

Industrial Security (Bachelor)

Section 04 – Industrial Protocols



Industrial Protocols

Lecture Notes

Department of Computer Science

2026-05-18

Industrial Security (Bachelor)

Section 04

Industrial Security (Bachelor)



Section 04 – Industrial Protocols

Industrial Protocols
Lecture Notes
Department of Computer Science

- 1 Legacy Heritage
- 2 Modbus
- 3 Siemens, DNP3, EtherNet/IP
- 4 Modern Secure Protocols

By the end of this section you will be able to

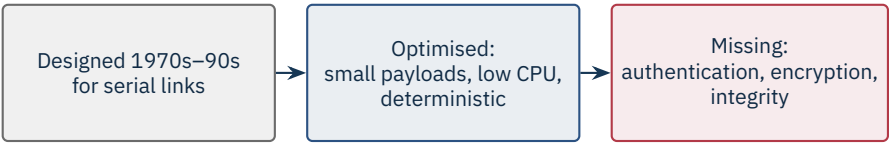
- Recognise common industrial protocols and their use cases.
- Understand why legacy protocols typically lack authentication.
- Decode a Modbus TCP frame by hand.
- Compare insecure legacy protocols with secure modern alternatives (OPC UA, MQTT-TLS).
- Identify when secure variants are appropriate.

1

Legacy Heritage

Core fact

Most industrial protocols in production today were **designed before the Internet** and provide no authentication, integrity, or confidentiality.



2026-05-18

Industrial Security (Bachelor)
└ Legacy Heritage

└ Why Industrial Protocols Are Different

Set the framing before naming any single protocol: these wire formats predate routine internet use and were drawn for trusted serial loops where the physical layer *was* the security boundary. Push back on the student reflex that “newer = better” — the same Modbus frame from 1979 still runs in greenfield plants today because it is cheap, deterministic, and works. Misconception to flag early: “but it runs over TCP now, so it must have TLS somewhere.” No — TCP only gives you a byte stream; it does not authenticate anything. Transition cue: “so let us look at the canonical example, Modbus.”

Why Industrial Protocols Are Different

04

Core fact

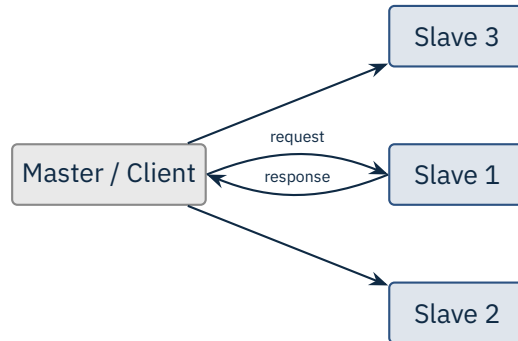
Most industrial protocols in production today were **designed before the Internet** and provide no authentication, integrity, or confidentiality.

```
graph LR; A[Designed 1970s-90s for serial links] --> B[Optimised: small payloads, low CPU, deterministic]; B --> C[Missing: authentication, encryption, integrity];
```

2

Modbus

Section 04 – Industrial Protocols



Variants: Modbus RTU (serial), Modbus TCP (port 502)
Address space: coils, discrete inputs, input regs, holding regs
No auth, no encryption – by design (1979)

Source: Modbus Organization, Modbus Application Protocol Specification v1.1b3, 2012.

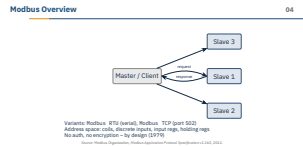
2026-05-18

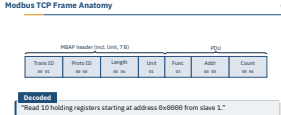
Industrial Security (Bachelor)

└─ Modbus

└─ Modbus Overview

Anchor Modbus in time: it is older than ARP, older than DNS, older than most students in the room. The design assumption was a private 4-wire RS-485 loop on the shop floor, not the internet. When you see Modbus TCP today it is the original PDU with a 7-byte MBAP header bolted on — function code intact, no auth, no integrity. Ask the room: “Shodan shows tens of thousands of devices on port 502 — what would you check first?” Steer them toward unit-ID enumeration and function-code 8 (diagnostics) before anything destructive. Transition cue: “let us decode an actual frame so you can read it on the wire.”





MBAP header (incl. Unit, 7 B)

PDU

Trans ID	Proto ID	Length	Unit	Func	Addr	Count
00 01	00 00	00 06	01	03	00 00	00 0A

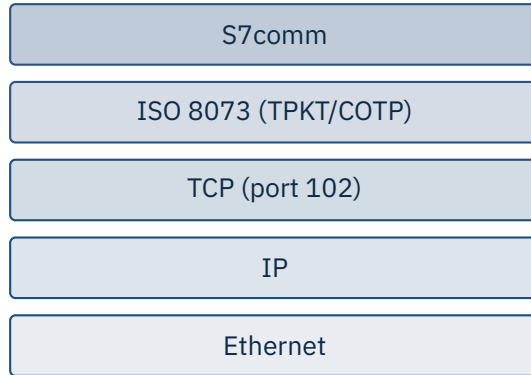
Decoded

"Read 10 holding registers starting at address 0x0000 from slave 1."

Walk the bytes left-to-right at the board: transaction ID is a client-chosen correlation cookie, protocol ID is always zero for Modbus, length counts everything from the unit byte onward. Stress that the unit ID was originally the RS-485 slave address and is now reused as a gateway selector — a single Modbus TCP endpoint can front a whole RTU bus. Common student misconception: they treat “Function 03” as read-only and therefore safe; remind them that Function 06 (single write) and 16 (multi-write) sit one byte away. Quick class question: “what changes in this frame if we want to write coils instead of read registers?” Answer: function code becomes 0x05 or 0x0F, plus a value field. Transition cue: “Modbus is the simple case — vendors like Siemens went their own way.”

3

Siemens, DNP3, EtherNet/IP



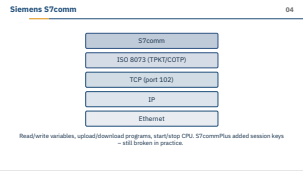
Read/write variables, upload/download programs, start/stop CPU. S7commPlus added session keys – still broken in practice.

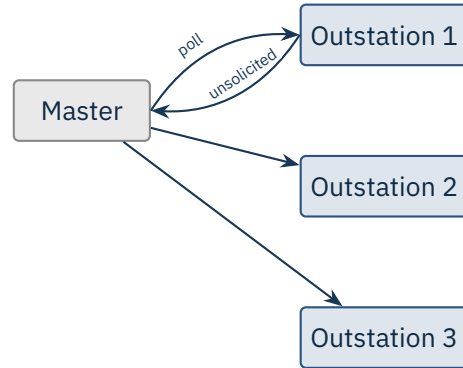
2026-05-18

Industrial Security (Bachelor)
 └ Siemens, DNP3, EtherNet/IP

 └ Siemens S7comm

Walk up the stack from Ethernet to S7comm so students see why classic packet captures show TPKT/COTP framing first — it is ISO transport over TCP because Siemens reused their pre-IP stack. The war story: S7comm has no authentication on classic S7-300/400, and the protocol was reverse-engineered well enough that Snap7 and python-snap7 give you full PLC control in a few lines. S7commPlus added an anti-replay handshake on S7-1200/1500, but researchers (Lei *et al.*, Biham, Plc-blaster) showed the key material was derivable; Siemens has rotated it several times. Misconception: “a firmware upgrade fixes it.” Often the upgrade silently changes the wire format and breaks third-party tools without actually adding cryptographic identity. Transition cue: “the utilities sector hit the same wall but answered differently.”





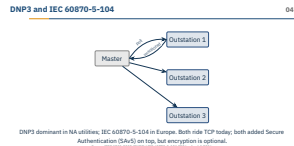
DNP3 dominant in NA utilities; IEC 60870-5-104 in Europe. Both ride TCP today; both added Secure Authentication (SAv5) on top, but encryption is optional.

Source: IEEE 1815-2012 (DNP3) | IEC 60870-5-104:2006 + Amd. 1:2016.

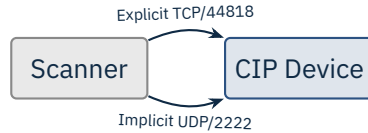
2026-05-18

Industrial Security (Bachelor)
└ Siemens, DNP3, EtherNet/IP

└ DNP3 and IEC 60870-5-104



Highlight the master/outstation model and the *unsolicited response* pattern — outstations push event data back without being polled, which is essential when a substation has a fault to report. War story: DNP3 SAv5 was standardised in IEEE 1815-2012 with HMAC-based challenge/response, and over a decade later real-world adoption in the field is still measured in single-digit percentages; utilities cite key-management overhead and the fact that the link layer is often a leased serial circuit they already trust. Misconception: “SAv5 means encrypted.” No — it provides authentication only; confidentiality requires bump-in-the-wire TLS or IPsec. Class question: “why might a utility leave SAv5 off even after they buy capable RTUs?” Transition cue: “Rockwell took yet another approach with EtherNet/IP.”



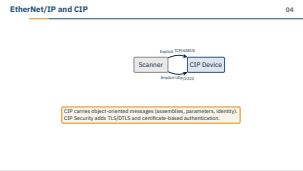
CIP carries object-oriented messages (assemblies, parameters, identity). CIP Security adds TLS/DTLS and certificate-based authentication.

2026-05-18

Industrial Security (Bachelor)
└ Siemens, DNP3, EtherNet/IP

└ EtherNet/IP and CIP

Make the split explicit: *explicit* messaging is request/response over TCP/44818 for configuration and diagnostics; *implicit* (a.k.a. I/O) is cyclic UDP/2222 multicast for the actual control data — which is why blocking 44818 alone does not stop a running line. CIP itself is an object model; EtherNet/IP is just CIP-over-Ethernet. War story: ODVA standardised CIP Security in 2015 with TLS for explicit and DTLS for implicit traffic, but Rockwell only ships it on newer ControlLogix 5580 / CompactLogix 5380 firmware, and rolling certificates across hundreds of drives is a project few sites have funded. Misconception: “EtherNet/IP is just industrial Ethernet.” No — the name is a marketing collision; it is CIP encapsulated in Ethernet frames, nothing to do with the EtherNet trademark. Transition cue: “Siemens did the same idea differently with Profinet.”



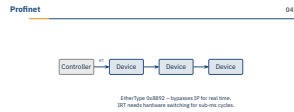


EtherType 0x8892 – bypasses IP for real time.
IRT needs hardware switching for sub-ms cycles.

2026-05-18

Industrial Security (Bachelor)
└ Siemens, DNP3, EtherNet/IP

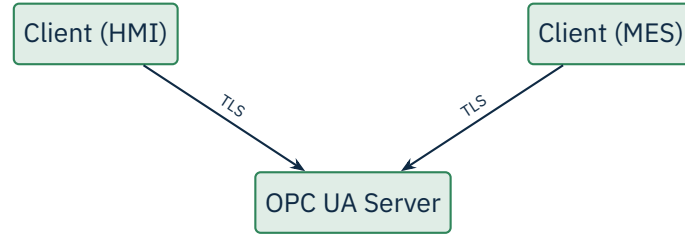
└ Profinet



Stress that Profinet RT lives at layer 2 – EtherType 0x8892, no IP, no TCP – specifically because the IP stack adds jitter that breaks deterministic cycles. Profinet IRT goes further and requires switches with hardware time-slotting (typically IEEE 1588 PTP) for sub-millisecond updates. Security war story: Profinet has long-standing weaknesses around DCP (Discovery and Configuration Protocol), which lets anyone on the local segment re-name or reset a device; multiple advisories (CERT@VDE, Claroty’s OT:ICEFALL set in 2022) catalogued this. Misconception: “it is layer 2 so it cannot be attacked remotely.” True – but most Profinet networks share VLANs with the engineering laptops, and a compromised laptop is on the wire. Transition cue: “so what does a protocol look like when security is designed in from day one?”

4

Modern Secure Protocols



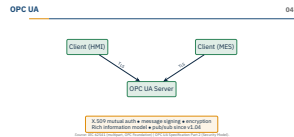
X.509 mutual auth • message signing • encryption
Rich information model • pub/sub since v1.04

Source: IEC 62541 (multipart, OPC Foundation) | OPC UA Specification Part 2 (Security Model).

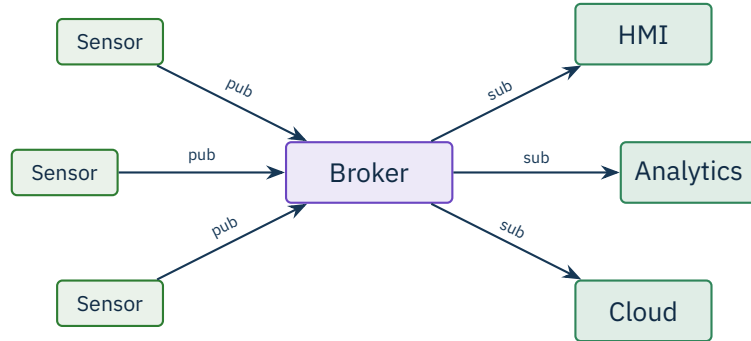
2026-05-18

Industrial Security (Bachelor)
└ Modern Secure Protocols

└ OPC UA



Sell OPC UA as the “protocol with seatbelts” — mutual X.509 authentication, signed messages, optional encryption, and a rich information model that lets you discover what a device *is*, not just what registers it has. Critical war story: the specification is over a dozen parts and a thousand pages; surveys (e.g. Kaspersky ICS-CERT, Claroty Team82 “OPC UA Deep Dive”) repeatedly find that a large share of real-world deployments run with security policy “None” and anonymous user tokens because that is the default in many configurators. Misconception: “OPC UA always uses TLS.” No — the binary transport has its own message-level crypto, and you must explicitly pick a SecurityPolicy like Basic256Sha256 or Aes256_Sha256_RsaPss; “None” is a valid choice. Class question: “how would you audit a plant to find anonymous-mode OPC UA servers?” Transition cue: “OPC UA is heavy — MQTT is the lighter modern option.”

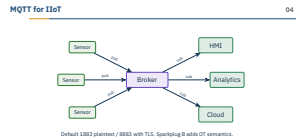


Default 1883 plaintext / 8883 with TLS. Sparkplug B adds OT semantics.

2026-05-18

Industrial Security (Bachelor)
└ Modern Secure Protocols

└ MQTT for IIoT



Frame MQTT as the publish/subscribe answer for IIoT: the broker is the choke point, sensors publish topics, anything authorised subscribes. Note the two ports – 1883 plaintext and 8883 with TLS – and remind students that Shodan finds hundreds of thousands of brokers on 1883 with no authentication and `#` wildcard subscriptions open. War story: in 2018 Avast scanned the open MQTT space and found brokers leaking smart-home, prison, and industrial telemetry; the situation has improved but not vanished. Sparkplug B (Eclipse Foundation) is worth mentioning because it adds the OT semantics MQTT lacks – state, birth/death certificates, structured payloads – and it is what most modern Unified Namespace deployments use. Misconception: “MQTT 5 is encrypted by default.” No – MQTT 5 added user properties and better error codes, not transport security; you still need TLS underneath. Transition cue: “let us put everything side by side.”

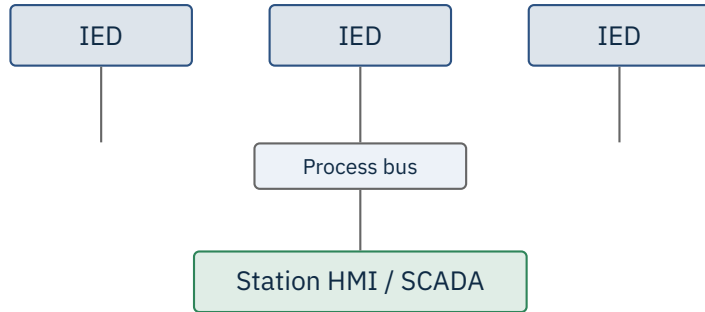
Protocol	Auth	Integrity	Confid.	Notes
Modbus	×	×	×	1979, ubiquitous
S7comm	×	×	×	Siemens-proprietary
DNP3	opt SAv5	opt	×	Utilities
EtherNet/IP	opt CIP	opt	opt	Rockwell
Profinet	weak	×	×	Siemens / IRT
OPC UA	X.509	sign	TLS	modern default
MQTT	+TLS	TLS	TLS	IIoT messaging

2026-05-18

- Industrial Security (Bachelor)
 - Modern Secure Protocols
 - Protocol Security at a Glance

Protocol	Auth	Integrity	Confid.	Notes
Modbus	×	×	×	1979, ubiquitous
S7comm	×	×	×	Siemens-proprietary
DNP3	opt SAv5	opt	×	Utilities
EtherNet/IP	opt CIP	opt	opt	Rockwell
Profinet	weak	×	×	Siemens / IRT
OPC UA	X.509	sign	TLS	modern default
MQTT	+TLS	TLS	TLS	IIoT messaging

Use the table to make a single argument: the security column is mostly a story about *defaults*. The protocols marked “opt” (DNP3 SAv5, CIP Security, MQTT+TLS) technically support strong crypto, but the boxes ship without it and the engineers configuring them rarely turn it on. Only OPC UA was designed with a non-trivial default — and even then operators routinely downgrade to SecurityPolicy “None” to fix interoperability. Misconception to puncture: “the green cells are safe protocols.” No, they are protocols where safety is possible; whether you got it depends on the deployment. Ask the class: “of these seven, which one would you put on a new greenfield project and why?” — there is no single right answer, the trade-off is determinism vs. security vs. ecosystem. Transition cue: “one application area pushes all of this to extremes — substations.”

**The substation stack**

MMS for client/server; **GOOSE** for sub-4 ms trip messages; **Sampled Values** for measurements. Goose has *no* authentication by default.

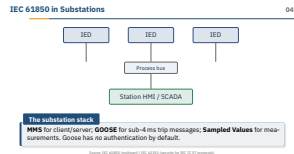
Source: IEC 61850 (multipart) | IEC 62351 (security for IEC TC 57 protocols).

2026-05-18

Industrial Security (Bachelor)
└ Modern Secure Protocols

└ IEC 61850 in Substations

Walk through the three services in order of latency budget: MMS for slow client/server, GOOSE for fast trip and interlock signals (layer 2 multicast, target end-to-end under 4 ms), and Sampled Values streaming raw current and voltage at the sampling rate of the merging unit. War story: a spoofed GOOSE frame can trip a breaker because the receiver only checks the state number and sequence; this exact attack family was demonstrated by Hoyos *et al.* and later operationalised by the CRASHOVERRIDE/Industroyer malware against the Ukrainian grid in 2016. IEC 62351-6 specifies authentication for GOOSE and SV, but few merging units actually implement it and switching it on adds latency the protection engineer may not tolerate. Misconception: “GOOSE is just multicast Ethernet, not a security concern.” It is exactly the lack of crypto on a high-trust safety bus that makes it interesting. Transition cue: “let us pull the section together.”



★ Key Takeaway: What to remember from this section

- Most legacy industrial protocols are unauthenticated and unencrypted by design.
- Modbus is the canonical example – 12 bytes of MBAP and a one-byte function code.
- Modern protocols (OPC UA, MQTT-TLS) bring real cryptography, but require correct configuration.
- Network-layer mitigations (firewalls, segmentation) compensate where the protocol cannot.

Land the section on one sentence: the protocol layer almost never gives you the security you want, so the compensating controls live in the network and in the process. Reinforce the Modbus number — 7-byte MBAP plus a one-byte function code is enough to read or write any register in any device on a bus, and that is the threat model most students will meet in their first OT engagement. Flag that the next section moves from *what is on the wire* to *how to put up walls around the wire*: firewalls, conduits, the Purdue model. If there is time, take one question on which protocol surprised them most — it is usually OPC UA, because the gap between specification and default deployment is the largest.

Summary – Section 04

04

★ Key Takeaway: What to remember from this section

- Most legacy industrial protocols are unauthenticated and unencrypted by design.
- Modbus is the canonical example – 12 bytes of MBAP and a one-byte function code.
- Modern protocols (OPC UA, MQTT-TLS) bring real cryptography, but require correct configuration.
- Network-layer mitigations (firewalls, segmentation) compensate where the protocol cannot.

- Modbus Organization. *Modbus Application Protocol Specification* v1.1b3, 2012.
- Modbus Organization. *Modbus/TCP Security*, 2018.
- IEEE 1815-2012. *Electric Power Systems Communications – DNP3*.
- IEC 60870-5-104:2006 + Amd. 1:2016. *Telecontrol equipment – Network access for IEC 60870-5-101*.
- IEC 62541 (multipart). *OPC Unified Architecture* (OPC Foundation).
- IEC 61850 (multipart). *Communication networks and systems for power utility automation*.
- IEC 62351 (multipart). *Security for TC 57 protocols*.
- OASIS. *MQTT Version 5.0*, 2019.
- ODVA. *The CIP Networks Library, Volume 1-8*, CIP Security spec.
- Siemens. *Step7 & S7 communication protocols* (S7comm, S7commPlus).
- Wightman, R. *Project Basecamp – ICS Vulnerability Catalog*, Digital Bond, 2012.

2026-05-18

- Modbus Organization. *Modbus Application Protocol Specification* v1.1b3, 2012.
- Modbus Organization. *Modbus/TCP Security*, 2018.
- IEEE 1815-2012. *Electric Power Systems Communications – DNP3*.
- IEC 60870-5-104:2006 + Amd. 1:2016. *Telecontrol equipment – Network access for IEC 60870-5-101*.
- IEC 62541 (multipart). *OPC Unified Architecture* (OPC Foundation).
- IEC 61850 (multipart). *Communication networks and systems for power utility automation*.
- IEC 62351 (multipart). *Security for TC 57 protocols*.
- OASIS. *MQTT Version 5.0*, 2019.
- ODVA. *The CIP Networks Library, Volume 1-8*, CIP Security spec.
- Siemens. *Step7 & S7 communication protocols* (S7comm, S7commPlus).
- Wightman, R. *Project Basecamp – ICS Vulnerability Catalog*, Digital Bond, 2012.

End of Section 04

Industrial Protocols

Questions and discussion

